Implement and manage Zero Trust Network Access(ZTNA) using Zscaler

TEAM LEADER: **G.ARUL KARTHIKA**

TEAM MEMBERS:

M.RUBAVARSHINI

P.KARTHIKA

U.KANISHKA

Project details

Title: Implement and manage Zero Trust Network Access(ZTNA) using Zscaler

❖ AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is a next-generation security framework that leverages artificial intelligence and machine learning to verify user identities and protect online platforms from cyber threats. Unlike traditional security measures that rely on static credentials like passwords or even two-factor authentication (2FA), AIUP continuously analyzes user behavior to create a dynamic, evolving "trust score" for each individual.

AIUP is essential for modern online security because it addresses the limitations of perimeter-based defenses. As cyber threats become more sophisticated—with attackers using stolen credentials, phishing, and social engineering—relying solely on "what you know" (passwords) or "what you have" (tokens) is no longer sufficient.

AIUP adds a third, continuous layer: "who you are" based on how you behave. This system helps organizations prevent account takeovers, reduce fraud, and ensure that the person interacting with a platform is genuinely who they claim to be, throughout their entire session.

Abstract:

The limitations of legacy VPN architectures in addressing modern security threats, particularly lateral movement and over-privileged network access, necessitate a paradigm shift towards Zero Trust principles. This project details the comprehensive design, deployment, and management of a Zero Trust Network Access (ZTNA) solution leveraging Zscaler Private Access (ZPA) within a largescale institutional network. The project aims to replace broad network-level access with application-specific, identity-driven connectivity. By deploying Zscaler App

Connectors within the data center and integrating the platform with existing Identity Providers (Azure AD) and endpoint security tools, the architecture ensures that all user-to-application connections are established through a cloud-native broker.

This approach renders internal applications "invisible" to the internet, eliminating the attack surface. Furthermore, the project explores the integration of Zscaler with security ecosystems, including SIEM platforms (like QRadar) for centralized logging and MISP for consuming threat intelligence to enable adaptive access policies. The result is a robust, scalable security framework that enforces least-privilege access, provides comprehensive audit trails, and significantly enhances the institution's resilience.

Use Case Scenarios:

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university's ERP system to upload student grades. Using Zscaler Private Access (ZPA), they connect securely without being placed on the internal network. The system verifies their identity via Azure AD MFA and checks their device posture before granting access.

Output:

- User identity verified (Faculty_Group)
- Device posture compliant (AV active, OS up-to-date)
- Secure micro-tunnel established to ERP Application only
- Network remains completely invisible to the user

Scenario 2: External Researcher Accessing a Specific Database

An external research collaborator from another institution requires temporary access to a single research database hosted on VIT's servers. The administratorcreates a time-limited, application-specific policy in Zscaler. The researcher accesses only the authorized database without any visibility into the rest of the VIT network.

Output:

•External user identity verified via temporary credentials

•Access policy enforced (Time-limited: 7 days, Application: Research-DB only)

•Database server remains hidden from internet scanners

•Session automatically terminates after policy expiry Scenario

3: **Student Access to Online Examination Portal**

During final exams, thousands of students simultaneously access the internal online examination portal from various locations. Zscaler ZPA ensures that only authenticated students with compliant devices can reach the exam server. The system prevents DDoS attacks on the login page and blocks any attempts to access other internal resources.

Output:

•Mass user authentication handled via cloud scalability

•Each student connected only to the exam application

•Lateral movement to grade database or other servers blocked

•Exam server IP address remains concealed from the internet**Scenario 4: IT Administrator Performing Server Maintenance**

An IT administrator needs to perform critical updates on an internal application server. Instead of connecting via VPN and gaining full network access, they use ZPA to connect directly to the specific server's management interface. The session is monitored in real-time, and any anomalous behavior (e.g., accessing unauthorized servers) is automatically terminated.

Output:

- Admin identity verified with MFA
- Direct micro-tunnel to Server-Management-Interface only
- All admin keystrokes and commands logged for audit
- Attempt to access another server automatically blocked

Scenario 5: Mergers and Acquisitions – Temporary Contractor Access

A contractor hired during a university system upgrade needs temporary access to a specific file server to migrate data. Using Zscaler ZPA, the contractor is granted application-specific access without being added to the university's Active Directory or given VPN credentials. The access is revoked automatically after the project timeline.

Output:

•Contractor identity verified via separate IdP integration

•Access granted to File-Server-Migration share only

•All file transfer activities logged in Zscaler and SIEM

•Access automatically revoked after 30-day project end date

Stage-1

Title Of the Project: Implement and manage Zero Trust Network Access(ZTNA) using Zscaler

Overview: -

The project aims to develop an AI-driven identity verification system that enhances online security by analysing and verifying user identities based on their online behaviour patterns. This system uses advanced machine learning techniques to create a robust user profile, distinguishing between legitimate users and suspicious activities. It addresses the pressing issue of unauthorised access, fraudulent transactions, and cyber threats across various online platforms and services.

The primary objective is to enhance online security significantly by scrutinising and validating user identities through their online behaviour. The system employs advanced machine learning techniques such as deep learning, neural networks, and natural language processing to establish comprehensive behavioural profiles for each user, which adapt and evolve with the user's behaviour over time. Real-time

anomaly detection is a key feature of the system, identifying deviations from established user behaviour profiles and responding promptly to mitigate potential security threats.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administratoralerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components inmultiple geographic regions.

REPORT: -

Practice Website: http://www.itsecgames.com/

1)Vulnerability Name: Improper Sanitization of File Paths
CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after**Steps to Reproduce:**
https://www.shodan.io/host/31.3.96.40

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation:

1.Apply Security Updates:

The primary recommendation is to apply the security update provided by Drupal as soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2.Review Configuration:

After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

3.Regular Audits:

Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.

Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.

5.Data Minimization:

Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality

2)Vulnerability Name: Invalid Certificate

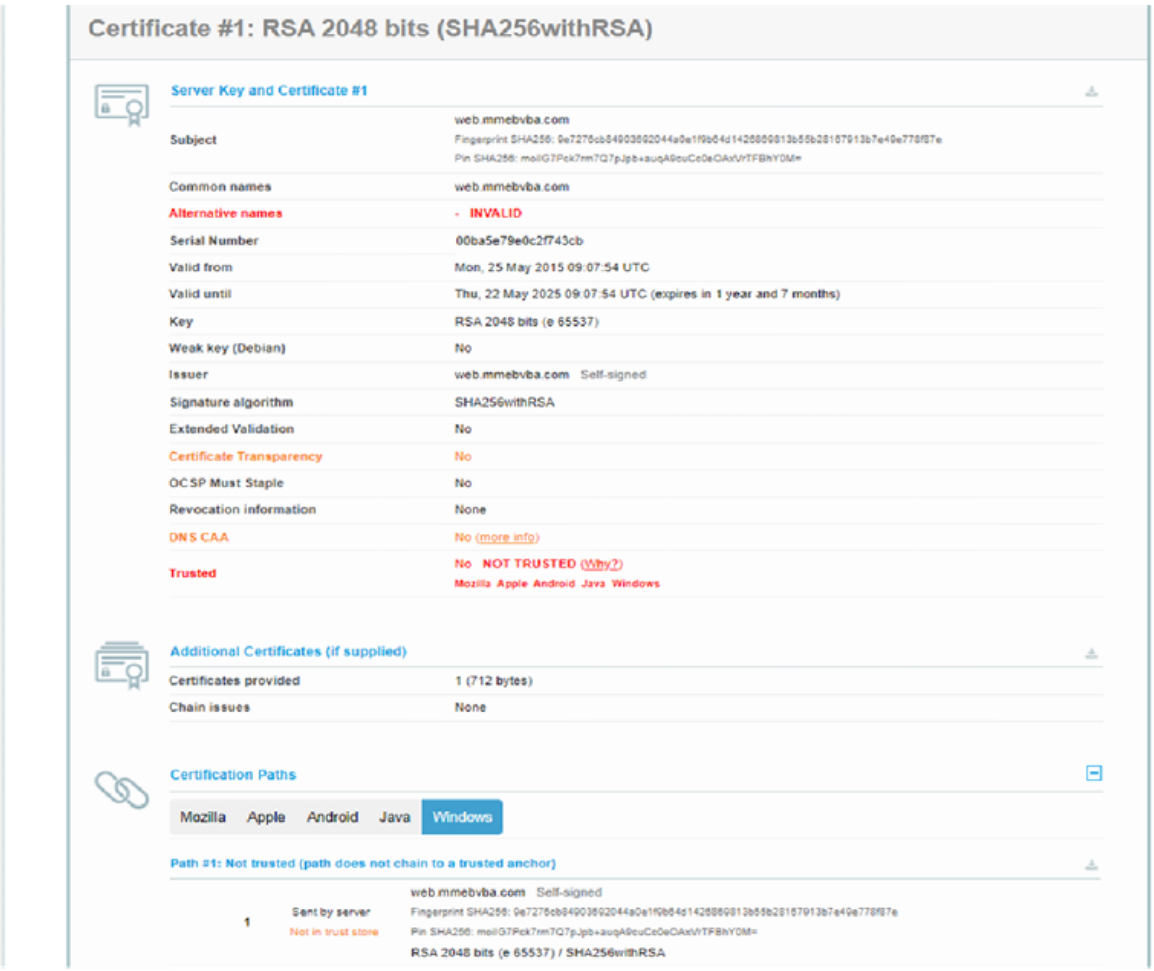
CWE-395: Improper Certificate Validation

OWASPCategory: A07:2021– Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Reproduce:
https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moiIG7Pck7rm7Q7pJpb+auqA6cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moiIG7Pck7rm7Q7pJpb+auqA6cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

Recommendation:

1.Use trusted certificate authorities: Only trust digital certificates issued by well-known and trusted certificate authorities.

2.Verify certificate chains: Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3.Check certificate revocation status: Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4.Use certificate pinning: Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5.Keep software up to date: Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3) Vulnerability Name: Missing X-Frame-Options Header
CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

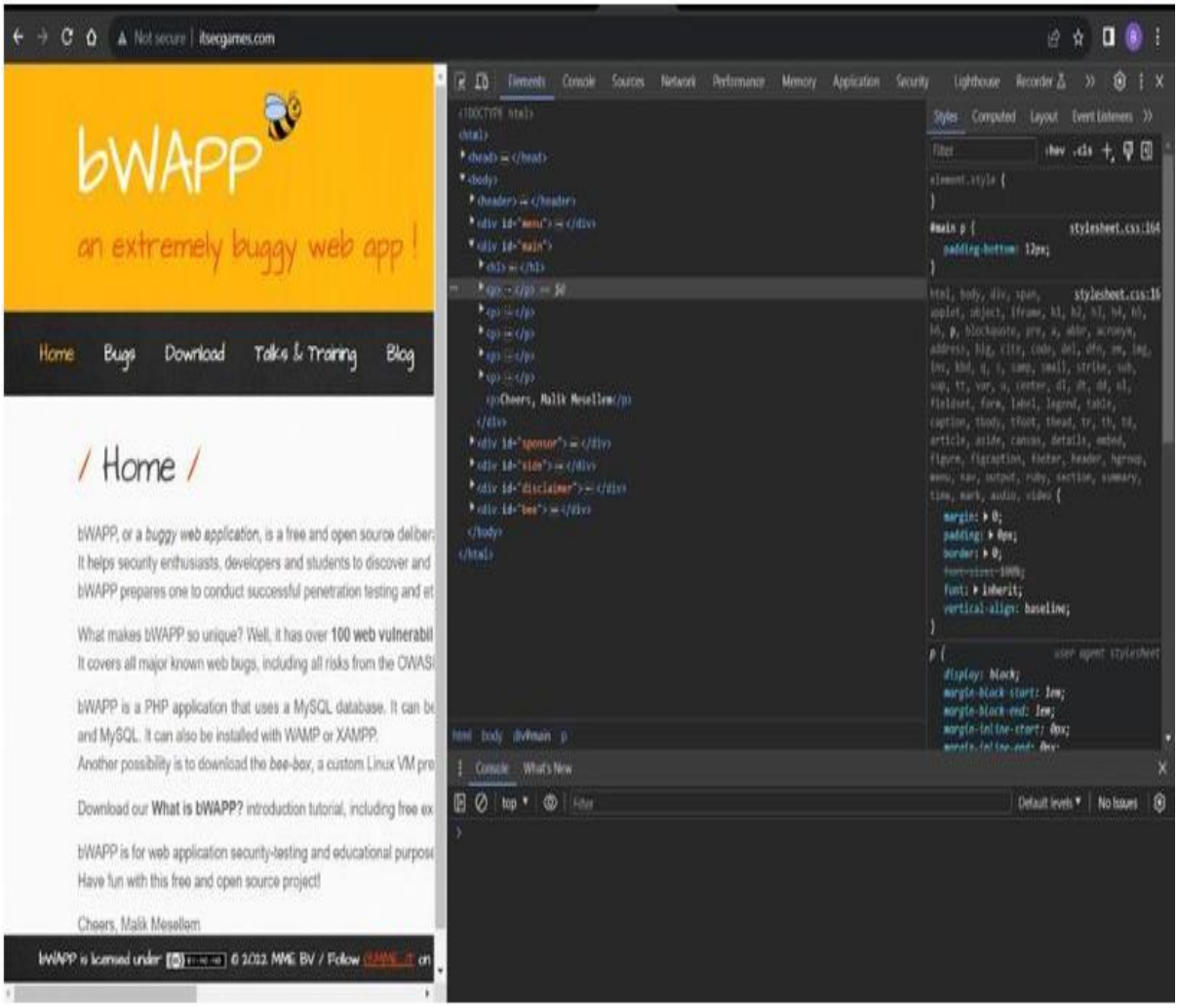
Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the

restrictions, users can be tricked into interacting with the application when they were not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.
Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

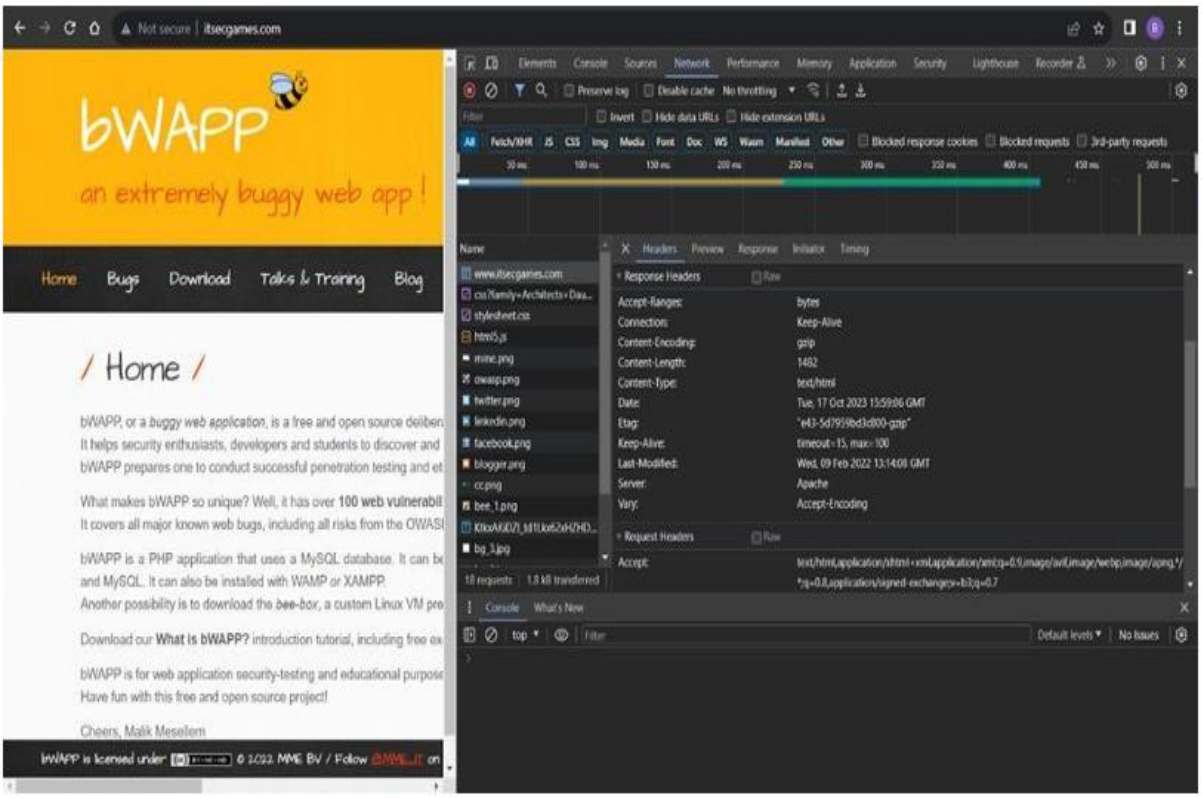
1. Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R

3. Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



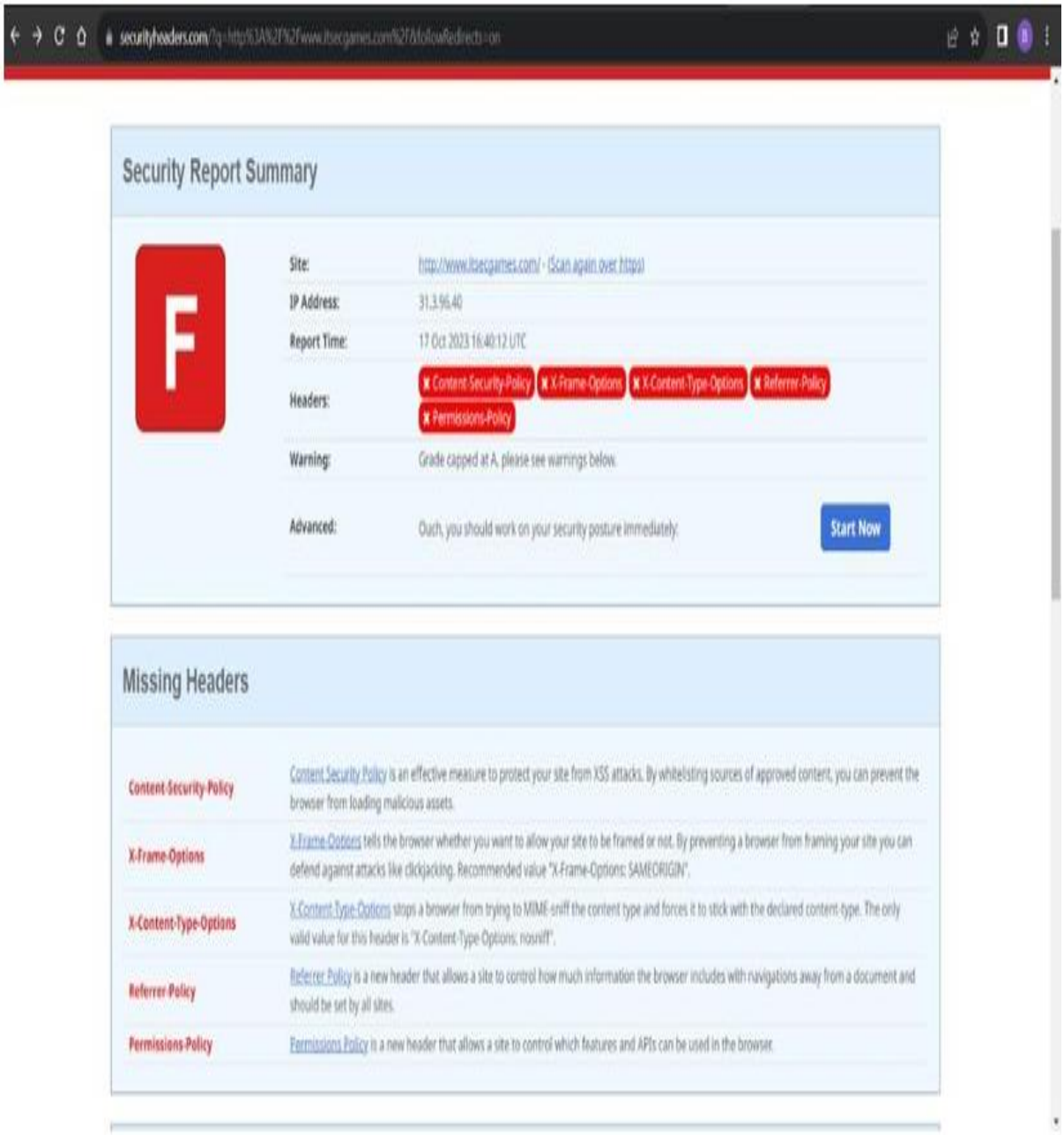
4) Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF) OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF) **Description:** The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's

reputation and trustworthiness) **Vulnerability Path :** https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects= on

Steps to Reproduce:



```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for

Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

REPORT: -

1) **Vulnerability Name: -** 104743 - TLS Version 1.0 Protocol Detection
   Severity: - MEDIUM
   Plugin: - 104743
   Port: - 443
   Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible. As of March 31, 2020,

Endpoints that aren’t enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors. PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2)Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

3)Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network.

Stage-3

Report: -

Title:-Implement and manage Zero Trust Network Access(ZTNA) using Zscaler

• Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is an IT security framework that provides secure remote access to an organization's internal applications and data based on clearly defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified.

ZTNA is a critical component of modern security architecture. It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castleand-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy

for every access request. It typically consists of the following steps:

1.User Request:

A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code repository).

2. Identity and Device Verification:

Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.

3. Policy Enforcement:

The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?

4. Establish Secure Connection:

If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-native security platform that delivers its services entirely from the cloud, eliminating the need for on-

premises hardware like VPN concentrators. For ZTNA, Zscaler offers Zscaler Private Access (ZPA) . ZPA is a service that provides seamless, identity-based access to private applications without ever placing users on the network.

Zscaler ZPA operates on a simple principle: the application is "inside" the Zscaler cloud, and the user connects to it there. It collects data from a variety of sources, including:

1. Identity Providers (IdP):

Such as Azure AD, Okra, or Ping Identity, to verify user identities.

2. Device Posture Partners:

Such as CrowdStrike, Tanium, or Microsoft Defender for Endpoint, to check the health of the endpoint.

3. Business Applications:

The internal web apps, file servers, and legacy applications hosted in data centers or public clouds (e.g., AWS, Azure).

• **The Zscaler ZTNA Cycle**

The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. **User Login and Authentication:** A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IdP) for authentication and MFA.

2.Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.

3.Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.

4.Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.

5.Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware. 6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 introduced the pivotal concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access (ZPA). It demonstrated a paradigm shift from traditional VPN-based network access to secure, identity-based user-to-application connectivity. The solution showcased the power of hiding internal applications from the internet, enforcing granular access policies, and eliminating lateral movement. This underscores the need for modern, proactive cybersecurity strategies in an era of remote work and cloud adoption. Considering the future scope.

Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration

and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

administrative access. **The network includes**:

•Core routers and switches

•Distribution routers and switches

•Wireless access points

•Firewalls and Intrusion Detection Systems (IDS)

•**Internal Application Servers:**Hosting the student information system, library resources, research data repositories, and administrative portals.

•**Legacy VPN Concentrator:**Currently providing broad network-level access for faculty and staff working remotely. The need for ZTNA arises from the limitations of the current VPN model:

•**Over-permissioned Access:**Once on the VPN, a faculty member's compromised laptop could potentially scan and attack the entire internal network (lateral movement).

•**Hidden Applications:**Some research applications need to be accessed by external collaborators without granting them full network access.

• How you think you deploy ZTNA using Zscaler in your college To deploy Zscaler ZTNA (ZPA) in your college, you would start by identifying the specific applications that need to be secured and the user groups that need access to them. This is a shift from securing the network to securing access to applications.

•**User Experience:**The legacy VPN can be slow and cumbersome, often requiring users to route all their internet traffic through the university.

THE END.